IdentityGuard (A-03)

Session Risk & Account-Takeover Detection | System Architecture & 12-Hour Execution Blueprint

Domain: Domain 2 — AI Systems & Infrastructure	**Target Timeframe:** 12-Hour Hackathon Execution	**Current Status:** Stage 1 Complete & Verified (Commit 3829939)

1. Problem Statement & Hackathon Winning Strategy

The Threat Model: Account Takeover (ATO) commonly starts when an intruder logs in from an unfamiliar device and geography, swiftly executing sensitive actions such as changing email credentials or requesting balance transfers. Standard heuristic engines trigger severe false alarms on legitimate travelers, remote workers, or device upgrades. Vague alerts (e.g., *'Suspicious Login'*) fail operational analysts.

The Strict Spec Invariants: The specification establishes definitive guardrails that separate winning solutions from disqualified entries:

- **The 5-Field Ingress Boundary (R1):** Input is strictly constrained to [timestamp, user, device_id, location_label, action]. No IP addresses, ASN numbers, device fingerprints, or client session IDs are assumed.
- **AI Is Advisor Only (R9):** Action-sequence AI models provide contextual probability scores, but are **strictly forbidden** from executing actions alone. An architectural compile-time and runtime circuit breaker enforces this.
- **Data Honesty over Hallucination (R4, R5, R7):** Missing locations or sparse user histories produce explicit not_evaluable signal states and limited evidence banners, never silent guesses.
- **100% Deterministic Replay (R10):** Both live streaming and analyst replays run through the exact same pure pipeline function, validated via SHA-256 cryptographic digest equality.
- **Terminal Revocation Gate (R11):** Once a session is revoked, all subsequent actions are immediately refused with HTTP 403 SESSION_REVOKED, blocked from profile learning.

2. Official Requirements Compliance Matrix (R1 to R11)

Req	Official Requirement	Architectural Solution	Status
R1	Receive 5-field events (ts, user, device, loc, action)	Pydantic V2 raw schema + ISO UTC normalizer	**VERIFIED**
R2	Learn each user's usual pattern from earlier events	Point-in-time Profile Engine (smoothed 24h histogram, device state)	**VERIFIED**
R3	Detect & explain 4 risk signals (S1-S4) with values & reasons	Modular detectors returning standardized SignalResult contracts	**VERIFIED**
R4	Handle sparse history gracefully	Evidence tiers (none/limited/sufficient); fallback to analyst review	**VERIFIED**
R5	Handle unknown location labels without guessing	Location alias DB; unresolvable marked UNKNOWN; S2 not_evaluable	**VERIFIED**
R6	Handle out-of-order, late, tied and duplicate timestamps	OrderingHandler with SHA-256 deduplication and late event tracking	**VERIFIED**
R7	State when judgement rests on limited information	Prominent evidence statement banner in all decision outputs	**STAGE 2**
R8	Apply configurable responses via explicit readable rules	YAML Rule AST Engine with 4 outcomes and strict precedence	**STAGE 2**
R9	AI advises action sequences; cannot trigger response alone	Markov sequence model + compile-time & runtime circuit breaker	**STAGE 2**
R10	Analyst replay of stored events with signals & responses	Sandboxed Replay Runner with side-by-side diff & SHA-256 hash	**STAGE 4**
R11	Revoked session must be refused all further actions	Session Gate: atomic HTTP 403 refusal at ingress and API	**STAGE 3**

3. System Architecture & Processing Pipeline

IdentityGuard is structured in a clean, decoupled architecture. The core detection and decision logic is isolated in a pure, zero-dependency Python package (core/) that does not import web frameworks or databases. This ensures identical determinism across live ingestion, automated tests, and offline replays.

Pipeline Stage	Functionality & Invariant	Component
1. Ingestion & Gate	Validates 5-field contract. Enforces **R11 Revocation Gate** immediately. Revoked sessions receive HTTP 403 without touching profile state.	core/normalize.py store/session_gate.py
2. Ordering Handler	Identifies on-time, late, duplicate (SHA-256 deduplicated), and future clock-skew events. Maintains arrival sequence.	core/ordering.py
3. Point-in-Time Profile	Constructs user pattern using only historical events where $T < T_{current}$. Evaluates evidence level (none, limited, sufficient).	core/profile.py
4. Signal Engine (S1-S4)	Evaluates measured facts against thresholds. Outputs standardized SignalResult with human-readable rationale.	core/signals/
5. AI Advisory Module	Scores action transition sequences via Markov model. Outputs advisory context. Evaluated behind strict runtime guard (R9).	core/advisory/markov.py core/advisory/guard.py
6. Rule Engine	Evaluates declarative YAML rules. Enforces response precedence: revoke > step_up > analyst_review > no_action.	core/rules/dsl.py core/rules/engine.py
7. Replay & Audit	Sandboxed execution of events against arbitrary rules. Generates cryptographic SHA-256 hash and side-by-side diff matrices.	replay/runner.py store/audit.py

4. Signal Catalog & Mathematical Formulations

Signal S1: Unfamiliar Device

Compares device_id against the user's historical devices. The first-ever device registered by a user is established as baseline (not unfamiliar). A device transitions from unfamiliar to known after 3 incident-free logins or verified step-up challenges.

Signal S2: Implausible Location Change (Haversine Geodesic Speed)

Calculates Great-Circle planetary distance between current and last known resolvable event locations:

$$d = 2R \cdot \arcsin(\sqrt{\sin^2(\Delta\phi/2) + \cos(\phi\blacksquare)\cos(\phi\blacksquare)\sin^2(\Delta\lambda/2)})$$

Implied velocity: $v = d / \Delta t$. Triggers if $v > 900$ km/h (airliner speed limit) AND $d > 50$ km. Plausible commercial flights (e.g., Pune to London in 10 hours = 720 km/h) evaluate to not_triggered. Unresolvable or missing locations evaluate to not_evaluable without guessing.

Signal S3: Unusual Activity Hour (Diurnal Density)

Constructs a 24-bin histogram in the user's home timezone, smoothed across circular adjacent hours:

$$P(h) = 0.25 \cdot P((h-1) \bmod 24) + 0.5 \cdot P(h) + 0.25 \cdot P((h+1) \bmod 24)$$

Triggers if $P(h) < 0.02$ (less than 2% of activity) AND the user has at least 5 active days. Users with fewer than 5 active days are marked not_evaluable.

Signal S4: Sensitive Action Post-Login

Correlates sensitive operations (change_email, change_password, request_transfer) occurring within 30 minutes of a login initiated from an unfamiliar device.

5. AI Core: Blended Markov Sequence Model & Circuit Breaker (R9)

Model Architecture: A first-order Markov Transition Matrix models the sequential likelihood of action tokens. To solve the cold-start problem, transition probabilities are dynamically blended between the user's personal counts and a global population prior matrix:

$$P_{blended}(a_t \mid a_{t-1}) = \lambda \cdot P_{user}(a_t \mid a_{t-1}) + (1 - \lambda) \cdot P_{global}(a_t \mid a_{t-1})$$

where $\lambda = min(1.0, N_{sessions} / 20)$.

Strict Architectural Enforcement (The Dual Anti-Bypass Guard):

1. **Compile-Time AST Verification:** The rule parser inspects all condition nodes. Any rule whose conditions reference only the AI advisory is rejected before activation.
2. **Runtime Circuit Breaker:** During evaluation, if a rule match occurred solely due to the AI advisory without corroboration from at least one deterministic signal (S1-S4), the engine forces the response to no_action and records an audit suppression flag.

6. Declarative Rule Engine & Precedence (R8)

Rules are defined in human-readable YAML format. Analysts can inspect, test, and hot-reload rules without code changes.

```yaml
rules:
  - id: R-06
    name: "Sensitive action after unfamiliar login + second risk signal"
    when:
      all:
        - signal: sensitive_after_unfamiliar_login
          is: triggered
        - any:
            - signal: implausible_location_change
              is: triggered
            - signal: unusual_hour
              is: triggered
    requires_evidence: sufficient
    if_evidence_lower: analyst_review
    response: revoke
    also_open_review: true
```

Precedence Order: revoke (1st) > step_up (2nd) > analyst_review (3rd) > no_action (4th).
Evidence-Aware Fallbacks: If rule R-06 matches but history is sparse (limited evidence), the response is automatically downgraded from revoke to analyst_review.

7. Replay Workbench & Cryptographic Audit Ledger (R10)

Sandboxed Replay: Analysts can re-run historical event batches against modified rules or thresholds. Replay uses an isolated ephemeral database and executes through the exact same core/pipeline.py code path. Determinism is cryptographically guaranteed by hashing decision outcomes (SHA-256).

Hash-Chained Audit Trail: Every state transition, manual analyst override, or rule update appends a row to an immutable audit table where $row_hash = SHA256(prev_hash + row_data)$, guaranteeing tamper-evidence.

8. 12-Hour Staged Execution Plan & Git Commit Blueprint

To ensure zero mistakes, complete reproducibility, and disciplined progress, the project is divided into 6 distinct stages. Each stage compiles, passes test suites, and corresponds to an atomic commit.

Stage / Time	Git Commit Message	Deliverables & Validation Checkpoint
Stage 1 (Hours 0-2.5)	feat(core): 5-field event contracts, normalizer, signals (S1-S4) & profile builder	**COMPLETED & COMMITTED (Commit 3829939).** 10 unit tests pass on geodesic speed, timezone smoothing, and 5-field schema validation.
Stage 2 (Hours 2.5-4.5)	feat(rules): readable YAML rule engine, precedence resolver & AI advisory guard (R8, R9)	Markov sequence model, YAML AST parser, precedence evaluator, compile/runtime AI guard, explanation templates.
Stage 3 (Hours 4.5-6.5)	feat(api): FastAPI endpoints, session gate enforcement (R11) and audit ledger	SQLite models, session state machine, atomic revocation gate returning HTTP 403, hash-chained audit logging, REST routes.
Stage 4 (Hours 6.5-8.5)	feat(replay): deterministic sandboxed replay engine and diff comparator (R10)	Replay runner in sandbox memory DB, side-by-side diff matrix, SHA-256 decision hash invariance verification.
Stage 5 (Hours 8.5-10.5)	feat(ui): glassmorphic analyst dashboard, replay workbench & target banking app	Analyst SOC dashboard, real-time live event feed, 24-hr circular histogram, Replay diff workbench, Target banking demo portal.
Stage 6 (Hours 10.5-12.0)	feat(demo): golden test fixtures, acceptance suite (R1-R11) and 1-click launcher	11 official acceptance tests (Section 18.1), 12 scenario test cases (Section 18.2), demo seeder, run.py 1-click boot.

9. Frontend Architecture: Analyst SOC & Target Banking Portal

Zero-Friction Serving Architecture: The frontend is built as a responsive Single-Page Application (SPA) served directly by FastAPI static endpoints using modern ES modules, Tailwind CSS, and Chart.js. This avoids npm/bundler friction and ensures judges can run the demo immediately with zero configuration.

Core UI Modules:

- **Incident Command Stream:** Real-time event ticker displaying user, location, action, risk status, and latency.
- **Signal Inspection Radar:** Detailed breakdown cards showing measured values, references, thresholds, and clear explanations.
- **User Profile Explorer:** Visual 24-hour circular activity chart, home timezone indicator, and trusted device tree.
- **Replay Workbench:** Interactive slider comparing historical vs. alternate rule sets with live diff highlights.
- **Live Target Banking Portal:** Embedded consumer banking app allowing judges to click 'Login', 'Transfer', and 'Change Email'. When malicious behavior triggers, the portal instantly locks out with a prominent HTTP 403 modal.

10. The 3-Minute Hackathon Winning Demo Script

1. **Minute 0-1 (Legitimate User & False Alarm Defense):** Show Asha logging in from Pune. Showcase her clean 24-hour histogram. Trigger a 10-hour flight to London: speed is 720 km/h (<900 km/h). IdentityGuard records S5 but produces no_action. Zero false alarms.
2. **Minute 1-2 (The Attack & Terminal Enforcement):** Attacker logs in from Dev-X in London 30 mins after Pune and clicks 'Change Email'. R-06 fires instantly. Show the banking app locking out immediately with HTTP 403 SESSION_REVOKED. Subsequent actions are blocked.
3. **Minute 2-3 (Honest Uncertainty & Deterministic Replay):** Show a sparse-history user (3 past events): R-06 auto-downgrades to analyst_review with a clear caveat. Open the Replay Workbench, modify thresholds, run replay, and demonstrate matching cryptographic SHA-256 hashes.